iA Financial Group

Information Security Corporate Policy

Privacy Notice

This document contains privileged and confidential information that is intended for the exclusive use of iA Financial Group.

Subject to approval by a duly authorized representative of iA Financial Group, any reproduction of this document, or its distribution outside its authorized group of users, is prohibited.

Table of contents

1. Introduction 3

a. Policy Objectives 3

b. Scope and Application 3

c. Definitions 3

2. Principles 5

a. Culture and Awareness 5

b. Governance and Responsibility 5

c. Information Security Risk Management 5

d. Information Security Frameworks 6

e. Information Protection 6

f. Detection 7

g. Information Security Incident Management 7

3. Main Roles and Responsibilities 7

a. Board of Directors 7

b. Risk, Governance and Ethics Committee (RGEC) 7

c. Executive Risk Management Committee (ERMC) 7

d. Senior Management 7

e. Chief Risk Officer (CRO) 8

f. Chief Information Security Officer (CISO) 8

g. Chief Information Technologies Officer (CIO) 8

h. Chief Data Officer (CDO) 8

i. Chief Privacy Officer (CPO) 9

j. Procurement and Material Resources 9

k. Management of Sectors 9

l. Internal Audit 9

m. Legal Services 9

Information Security Corporate Policy	
Owner	Executive Vice President and Chief Risk Officer of iA Financial Corporation inc.
Scope	Group
Approval body	Board of directors upon recommendation by the Risk, Governance and Ethics Committee
Initial approval date	January 24, 2008
Revision date	February 18, 2025
Review frequency	Every two (2) years, or when significant changes require an amendment to the Policy
Next revision	February 2027

1. Introduction

a. Policy Objectives

The *Information Security Corporate Policy* (hereinafter referred to as the "**Policy**") establishes the principles underpinning the Information Security framework within iA Financial Group.

The objectives of the Policy are as follows:

- To communicate Senior Management's expectations regarding Information Security;
- To insure implementation of a functional governance structure delineating Information Security roles and responsibilities; and
- To insure implementation of frameworks aimed at promoting sound and prudent management of Information Security risks while concurrently facilitating the achievement of corporate objectives.

b. Scope and Application

The Policy shall be applicable to iA Financial Group and all its Subsidiaries.

c. Definitions

"**Asset Owner**" refers to an organizational role associated with an Information Asset. For data, this responsibility is assigned to a data responsible. For the purposes of the Policy, the term refers to both IT Asset owners and data responsible.

"**Availability**" refers to the property of being accessible and usable on demand by an authorized entity or person.

"Board of Directors" refers to the entire Board of directors of the Company. or, as applicable, a committee to which the Board of directors has entrusted a specific aspect of its roles and responsibilities under the terms and conditions of the mandate that has been entrusted to it.

"**CDO**" refers to the Chief Data Officer for iA Financial Group.

"**CIO**" refers to the Chief Information Technology Officer for iA Financial Group.

"CISO" refers to the Chief Information Security Officer for iA Financial Group.

"**Company**" refers to, individually, iA Financial Corporation or any of its Subsidiaries.

"Confidentiality" refers to the property that information is not accessed, disseminated or disclosed to unauthorized persons, entities or processes.

"**CPO**" refers to the Chief Privacy Officer for iA Financial Group.

"**CRO**" shall refer to the Executive Vice President and Chief Risk Officer of iA Financial Corporation.

"**ERMC**" refers to the Executive Risk Management Committee of iA Financial Corporation, which is the central forum responsible for overseeing iA Financial Group's integrated risk management.

"**GRMC**" refers to iA Financial Corporation's Group Risk Management and Compliance.

"iA Financial Corporation" refers to iA Financial Corporation Inc.

"iA Financial Group" refers collectively to iA Financial Corporation and its Subsidiaries.

"**Information Asset(s)**" refers to any Information system or support, information technology, installation or any combination thereof, acquired or constituted by iA Financial Group (i.e., the technology asset or IT asset) and any Information, regardless of the communication channel or its medium, representing value to iA Financial Group (i.e., the data or data asset).

"Information" refers to contextualized and organized data or content.

"**Information Security**" refers to the preservation of the Confidentiality, Integrity and Availability of information.

"Information Security Incident(s)" shall mean an attack on the Availability, Integrity or Confidentiality of Information Assets.

"Integrity" refers to the property of protection against improper modification or destruction of information, including the guarantee of non-repudiation and authenticity.

"**Management**" refers to employees who occupy a Management role within a Sector, including in particular directors, vice-presidents and executive vice-presidents.

"RGEC" refers to Company's Risk, Governance and Ethics Committee, which is responsible for supporting its Board of Directors in its governance, ethics and risk management responsibilities.

"Sector(s)" refers to one or more commercial organizational unit(s) or a support organizational unit(s) within iA Financial Group for which an executive vice-president of iA Financial Corporation is responsible for.

"**Security Control(s)**" refers to a measure that maintains or mitigates risk. Controls include, but are not limited to, any process, policy, device, practice, or other conditions or actions that maintain or mitigate risk.

"Senior Management" refers to the members of iA Financial Corporation's executive committee.

"**Subsidiary (ies)"** refers to a legal entity controlled, directly or indirectly, by iA Financial Corporation.

"Supplier(s)" refers to a person or legal entity that provides goods or services necessary for the production or operation of an iA Financial Group.

2. Principles

The Policy defines the principles to which iA Financial Group adheres to ensure the Confidentiality, Integrity and Availability of the Information under its responsibility. Adherence to these principles is intended to reinforce iA Financial Group's Information Security posture and culture.

a. Culture and Awareness

iA Financial Group is committed to sound and proactive management of Information Security risks to protect its customers, partners and employees. Senior Management shall be responsible for providing leadership in this area and for promoting an Information Security culture within iA Financial Group.

iA Financial Group's Information Security culture shall encourage the adoption of prudent and diligent behavior by all individuals and legal entities who use or access the Company's Information Assets, commensurate with the sensitivity of the Information in question.

iA Financial Group shall implement an Information Security awareness and training program, particularly concerning the safe use of Information Assets and the reporting of Information Security Incidents.

b. Governance and Responsibility

Senior Management shall assign responsibilities regarding Information Security within iA Financial Group, ensuring a clear separation of duties between the various parties involved.

A Chief Information Security Officer (CISO) shall be appointed for iA Financial Group. The mandate of the CISO, in addition to that set forth in this Policy, is defined by Senior Management. Specifically, the CISO defines the Information Security strategy and oversees its implementation. The Information Security strategy must contribute to the achievement of iA Financial Group's objectives. The hierarchical positioning of the CISO and the responsibilities assigned to them must foster his independence and objectivity concerning Information Security activities under the responsibility of the Sectors. The role of the CISO is to supervise these Information Security activities.

This positioning shall be supported by a governance structure proposed by the CISO and approved by the appropriate governance bodies, defining the roles and responsibilities of the various stakeholders concerning the management and implementation of Information Security, in addition to what is set forth in this Policy.

Within the three lines of defense model established by iA Financial Corporation's *Integrated Risk Management Corporate Policy*, the positioning of the CISO is reflected by their distinct role (*first line of defense 1B*) from the Sectors in their day-to-day activities (*first line of defense 1A*) and the second line of defense.

Responsibility for Information Security within iA Financial Group is shared between the various stakeholders according to their roles. An Asset Owner shall be designated for each Information Asset. Responsibility for its management, use and protection shall be assigned to this person.

c. Information Security Risk Management

Information Security risk management is part of iA Financial Group's risk management framework. The risk taxonomy considers risks relating to the Availability, Integrity and Confidentiality of Information.

The principles set out in the *Integrated Risk Management Corporate Policy* and the *Operational Risk Management Corporate Policy* apply. The Sectors in their day-to-day activities (*first line of defense 1A*) are the takers of risks. They are responsible for identifying, assessing and managing risks (such as defining risk response) related to Information Security.

An internal Security Controls framework comprising key controls that consider the significant risks identified for the organization must be defined, documented in the appropriate frameworks and implemented. Sectors must ensure that they implement the necessary Security Controls in line with their risks, while respecting risk tolerance.

In terms of risk management, the CISO provides guidance and support (*line of defense 1B*) to the Sectors but cannot replace them. These functions include reviewing action plans to confirm to risk takers that the actions defined adequately mitigate the risks identified. The CISO works closely with the GRMC (*second line of defense*) in the latter's monitoring and reporting of Information Security risks.

Security Controls are periodically subjected to various types of independent assessment, testing and review to validate their effectiveness, employing the most appropriate measures based in particular on the materiality of the associated risks.

Periodic risk monitoring allows to achieve and maintain a level of residual risk in line with the appetite and tolerance established for iA Financial Group. To this end, reports and indicators are produced and monitored periodically, at Sector or consolidated level.

d. Information Security Frameworks

Information Security frameworks are documented, kept up to date and implemented throughout iA Financial Group. These frameworks are the responsibility of the CISO, who ensures their development and evolution in collaboration with other concerned stakeholders. They are based on international standards and industry best practices. They must consider applicable legal and regulatory requirements. The Policy and these frameworks constitute the Information Security policy framework.

Deviations from Information Security frameworks must be identified, documented and monitored as part of a risk-based approach.

e. Information Protection

Information Assets are protected by means of Security Controls proportional to their value, notably based on classification and categorization criteria. Security Controls address all aspects of Information Security, both internal and external (e.g. linked to a third party), such those relating to IT systems and applications, physical environment and individuals.

In the case of IT systems and applications, the required Security Controls must be identified at the design stage, to ensure upstream protection of the Information (*Security by Design*). The Asset Owner is responsible for applying and configuring the required Security Controls to adequately manage the associated Information Security risks.

In terms of physical security, Security Controls must be implemented for buildings providing access to Information Assets, whether under the responsibility of the Company or a third party.

Company must put in place a sound access and identities management. Access to Information Assets is granted only to authorized individuals in accordance with the principles of least privilege, need-to-know and segregation of duties.

f. Detection

Information Security events, system and application vulnerabilities and emerging threats are managed proactively to prevent risks from materializing.

To this end, processes for digital investigation, threat management, vulnerability management and security monitoring and analysis are defined and implemented within the Company.

g. Information Security Incident Management

Frameworks, procedures and mechanisms must be in place for the identification, management and timely reporting of Information Security Incidents to appropriate internal and external stakeholders, such as the Company's Management, regulatory authorities, third parties and the Company's customers (both individuals and legal entities).

These frameworks, procedures and mechanisms must be clear, particularly in terms of roles and responsibilities, in addition to being responsive and risk based. They should be designed to contain the potential impact of Information Security Incidents and accelerate the return to normal operations.

3. Main Roles and Responsibilities

a. Board of Directors

i. Approves the Policy and any amendments thereto, if any.
ii. Ensures that an individual is designated to oversee deployment of the Policy and Information Security frameworks.

b. Risk, Governance and Ethics Committee (RGEC)

i. Reviews and recommends the Policy and its amendments, if any, for approval by the Board of Directors.
ii. Receives periodic reports from the CRO on risks and significant Information Security events.

c. Executive Risk Management Committee (ERMC)

i. Reviews and recommends the Policy and its amendments to the RGEC, if any, for approval by the Board of Directors of iA Société financière.
ii. Receives periodic reports from the CRO on risks and significant Information Security events.

d. Senior Management

i. Promotes and disseminates a culture of Information Security.
ii. Ensures that the Policy's principles are integrated into the values, strategic objectives and decisions, thereby promoting behaviors that demonstrate a genuine commitment to Information Security.
iii. Appoints a Chief Information Security Officer (CISO) and defines their mandate.
iv. Ensures that Sectors designate responsible parties for all Information Assets and Information Security risks.
v. Supports Management in developing their leadership in Information Security, in accordance with their areas of responsibility.
vi. Ensures the availability of structures, support, resources and processes for Information Security.

e. Chief Risk Officer (CRO)

i. Develops the Policy and monitors its deployment within iA Financial Group.
ii. Monitors Information Security risks independently and in close collaboration with the CISO.
iii. Synthesizes, disseminates and effectively communicates information on Information Security risks to various bodies.
iv. Oversees the management and reporting of Information Security Incidents.
v. Reports to the ERMC and RGEC on risks and significant Information Security events, in accordance with the *Integrated Risk Management Corporate Policy.*

f. Chief Information Security Officer (CISO)

i. Defines the Information Security strategy and oversees its implementation.
ii. Define clear Information Security objectives for systems, technology services, processes, buildings and people.
iii. Develops Information Security frameworks, including an internal Security Controls framework, monitors their deployment within iA Financial Group and tracks deviations from them in a risk-based approach.
iv. Validates the effectiveness of the Security Controls deployed for Information Assets, employing the most appropriate measures based on the materiality of the associated risks.
v. Develops and implements an Information Security awareness and training programs in collaboration with relevant stakeholders.
vi. Supervises or participates in the Information Security Incident response with relevant stakeholders, in accordance with frameworks and processes.
vii. Supports Sectors in managing their Information Security risks.
viii. Reports to the CRO on Information Security risks, significant events and posture.
ix. Supports the CRO in applying the Policy.

g. Chief Information Technologies Officer (CIO)

i. Ensures that Information Security is integrated into planning, orientations and frameworks relating to enterprise architecture and the use of IT systems and applications, and that these are effectively implemented across Sectors in accordance with risks.
ii. Deploys the Security Controls for which they are responsible and ensures their effectiveness.
iii. Ensures that the capability to prepare for, detect and respond to technological Information Security Incidents is appropriate.
iv. Supports Sectors in managing their Information Security risks related to the Availability of Informational Assets.
v. Reports to the CRO on Information Security risks and significant events related to the Availability of Informational Assets.
vi. Supports the CRO in applying the Policy.

h. Chief Data Officer (CDO)

i. Ensures that Information Security is integrated into data frameworks for which they are responsible, and that these frameworks are effectively implemented across Sectors.
ii. Supports the CISO in developing frameworks related to the protection of data under their responsibility.

i. Chief Privacy Officer (CPO)

i. Validate that the Information Security frameworks are sufficiently robust to enable iA Financial Group to meet its privacy obligations.
ii. Ensures that privacy and Information Security frameworks are aligned.

j. Procurement and Material Resources

i. Deploys the physical security controls for which they are responsible and ensures their effectiveness.
ii. Ensures that Information Security requirements specified in Information Security frameworks are integrated and considered in the procurement process and in relations with Suppliers, depending on the level of risk.

k. Management of Sectors[1]

i. Support the Company's commitment to Information Security.
ii. Designate and supports Asset Owners within their Sector.
iii. Implement the appropriate Security Controls within their area of responsibility, in accordance to the level of risk, to ensure compliance with Information Security frameworks.
iv. Identify and document deviations from the Information Security frameworks applicable to their activities and Information Assets and inform the CISO.
v. Identify, assess and manage Information Security risks in the day-to-day operations of their Sector, including those related to the Information Assets under their responsibility.
vi. Establish and implement appropriate action plans related to Information Security risks and maintains their status.
vii. Report Information Security risks and events to the CISO periodically, and in real time if necessary.
viii. Report to the CRO on out-of-tolerance risks and significant events within their Sector.
ix. Declare Information Security Incidents via the appropriate channels, in accordance with the procedures and mechanisms in force.
x. Ensure that employees in their Sector utilise the security services provided and that they are adequately informed and trained in Information Security.

l. Internal Audit

i. Provides assurance and independent and objective guidance on the compliance, adequacy and effectiveness of governance and management controls, as well as on the management of Information Security risks, to contribute to the achievement of iA Financial Group's objectives and to promote and encourage continuous improvement.

m. Legal Services

i. Advise stakeholders and Sectors on their legal and regulatory obligations with regards to Information Security.

---

[1] This function includes the role of Asset Owner.

ii. Ensure legislative and regulatory oversight in relation to Information Security, including monitoring, interpreting and communicating legislative and regulatory changes to stakeholders.